OpenHarmony-Audit-Agent 工具源代码技术说明书

本说明书对应题目一交付件 2，描述工具原理、代码实现与接入边界。具体漏洞、CVE、PoC 结果及影响版本由参赛团队后续提供。本文件不构成漏洞分析报告。

1. 工具定位

OpenHarmony-Audit-Agent 以角色化代码审计工作流为主体。主体负责目标拆分、源码调查、安全不变量提取、同类问题搜索、反证检查、候选冻结、独立盲验证、PoC 计划和人工复核材料。CodeQL-AI 是按需调用的辅助验证能力，用于检查特定路径、保护函数或查询模型。

候选可以直接来自源码审计、人工不变量、获准的历史修复信息或静态告警。CodeQL 告警不是启动审计的必要条件。辅助工具缺席时，工作流仍可开展具备条件的调查，并在报告中保留验证缺口。

主体使用大模型进行跨文件语义分析与任务组织。可信性来自可重放的源码引用、明确的假设、主动反证、独立复核以及适用范围内的确定性验证。工具的存在本身不证明效果提升；增益通过对照实验测量。

2. 总体流程与职责

主体流程为：目标快照与分片 → 源码调查与不变量提取 → 角色交接与反证 → 冻结候选 → 独立盲验证 → 获准的历史核查与 PoC 计划 → 证据审核及人工复核。候选在需要时发起辅助检查，结果回到同一候选版本。

入口角色核对攻击者、信任边界和可控参数。数据流角色核对容量、整数、对象生命周期及危险操作。反证角色寻找调用方限制、权限检查和保护路径。chain-composer 组织逐跳调用链，总控合并同根因项并发布固定版本。blind-verifier 使用独立上下文重建候选，不接收发现者的期望结论。历史查重在盲验证之后按授权范围执行；缺少历史时保留未知状态。

单个 worker 只处理分配到的 analysis unit。总控发布候选，其他角色返回调查产物。共享验证资源按配置串行使用。每个候选记录已完成事项、未解假设和下一步检查，供 checkpoint 恢复。

3. 目录和功能实现

模块	入口与主要行为
cli.py	主入口；workflow 子命令转发至 generic_cli；兼容 validate-target、prepare、normalize-sarif 和 report
workflow/generic_contracts.py	解析 WorkflowConfig、TargetProfile、AnalysisUnit；检查标识、相对路径、阶段、角色和运行时参数
workflow/generic_adapters.py	目录、Git 仓库与反编译树接口；提供源码上下文与分析单元；strict 模式检查源目录与单元存在性
workflow/generic_planner.py	按权重降序分配到当前负载最小的 worker；生成 plan、assignment、角色与盲验证提示词，并注入可选辅助策略
workflow/generic_runner.py	ThreadPoolExecutor 运行 root workers；调用 Claude Code stream-json；记录 controller/checkpoint 日志，按终态与 maxCycles 控制轮次
workflow/checkpoint.py	JSON 检查点读取；先写临时文件后 os.replace 原子替换。与 Agent 维护的 worker-state 协议配合
workflow/scheduler.py	记录阶段事件；当前不承担自动调用 provider 或证据归档
contracts/models.py	Campaign、Finding、CandidatePacket、Evidence、Decision、ExperienceRecord 数据类及 JSON 序列化；Evidence 计算内容 SHA-256
evidence/normalizer.py	读取 SARIF runs/results/codeFlows 并保留输入哈希；为可选静态告警提供统一输入
evidence/decision_gate.py	按关联候选、源码/静态证据、调用链、不变量、反证和已复核结果输出四态结论
engines/codeql_ai/providers.py	包装原 CodeQL-AI 的经验、查询、函数读取和符号验证接口；可通过 MCP 服务接入 Agent
runtimes/	Claude Code 与 OpenAI-compatible 独立适配器；主体并行 runner 当前接入 Claude Code
reporting/	从内置模板生成本技术说明书 Markdown 与 PDF；模板不是漏洞分析结果

4. 主体运行机制

workflow validate 检查配置和提示词资源；默认可对抽象路径做结构检查，严格源目录检查需要 --strict-source。workflow plan 生成确定性分片计划，不调用模型。workflow prepare 创建独立 worker 目录、任务包、角色提示词和共享候选/复核/报告目录。--allow-missing-source 仅用于抽象目标准备。

workflow run 消费已准备任务包，启动配置的 Claude Code；实际使用必须配置可用模型、认证与真实源码。每轮检查 worker-state.json 的 terminal 和允许终态，未结束时运行 checkpoint 会话，在下一轮继续。已有终态会跳过。workflow status 读取落盘状态。run 不自动执行官方漏洞提交或外部披露。

状态记录和恢复协议已保留，但完整的 OpenHarmony Agent 执行、MCP 配置、独立上下文隔离和设备适配需要在目标环境联调。配置接口名称不代表对应后端已经实现。OpenAI-compatible 独立适配器不能直接替换目前仅

支持 Claude Code 的并行 runner。

5. 候选与证据交接

CandidatePacket 包含稳定 ID、revision、源码快照、单元、位置、调用链、不变量、威胁模型、影响、反证记录和未解假设。冻结通过版本协议实现；数据类本身并不提供不可变存储。实质修改使用新 revision，已有证据保留原版本归属。

Evidence 包含 producer、candidate_id、source_ref、input_hash、content_hash、规则/模型版本、时间和执行状态。主体源码调查可生成 source_review；静态告警、保护函数、符号结果、历史信息和 PoC 执行均可提供不同类型证据。缺失来源字段不应被填成虚构凭证。

当前决策接口要求 available 证据归属于当前 candidate_id。已复核的决定性反证可得到 REJECTED。基础证据不足得到 NEEDS_EVIDENCE。源码审计或静态路径加上位置、调用链、不变量、威胁模型与至少两条反证记录可保留 STATIC_ONLY。CONFIRMED 另外要求独立复核标志，以及来源/哈希非空、snapshot 与 revision 相符、reviewed=true、result=supported 的确定性验证记录。

这些检查是结构性条件，不会验证哈希所指文件的真实性。调用方必须实际核验原始产物，再设置 reviewed。仅凭模型 confidence、工具类型名或失败结果不能确认漏洞。尚未对所有证据类型实现严格 Schema、签名与范围验证，不能将该判定函数当作完整信任边界。

6. CodeQL-AI 辅助机制

FP Experience 检索相似误报模式，帮助提出反证问题。Function-Level Sanitizer 搜索与读取路径上的保护函数。QL Optimizer 生成独立查询修补，需要重跑和正负例回归；查询修补与目标源码安全修复属于不同产物。Symbolic Sanitizer 在给定二进制、路径、分支选择与攻击谓词下执行局部验证。

调用前应固定候选版本、问题与输入；返回后检查错误、超时、模型假设和覆盖范围。SAT 只说明约束内存在见证；UNSAT 只覆盖被验证的路径；UNKNOWN、错误或超时不得用作排除理由。低置信度经验只提供线索。通过回归的经验也需要核对代码版本与适用条件。

本仓库已有 provider、MCP 入口和注入主体任务包的辅助策略。自动把 provider 输出规范化为完整 Evidence、校验并归档的总控闭环尚未完成；不能把 HTML 里的交接动画当成真实后台执行。

7. OpenHarmony 适配与输出约定

抽象目标覆盖 IPC / Parcel、NAPI 回调、权限身份、缓冲区、整数和生命周期。实际任务应固定社区源码来源、tag/commit、模块路径、构建信息与攻击者能力；多仓库工程应保存版本清单。硬件与系统服务验证由单独 adapter 接入。

后续漏洞材料应包含源码位置与相关内容、CWE、已公开 CVE（如有）、触发条件、调用链、可执行 PoC 与运行环境、影响模块和分支、修复建议或补丁。当前技术说明书与方法演示不填入这些尚未提供的真实结果。报告字段与 PoC planner 协议不等同于已完成具体漏洞的 PoC 开发。

8. 效果与性能评价方法

以主体工作流作为主要基线，对比主体加按需辅助验证。单独 CodeQL 作为外部参照，分别移除角色、反证或辅助检查做消融。固定源码快照、输入线索、模型、预算、候选数量及复核标准；分别观察候选准确性、已知基准召回、复核耗时和未解决比例。

性能按任务准备、主体审计、可选 CodeQL 建库/查询、辅助验证及报告阶段分别测量。记录源码规模、覆盖范围、并发数、端到端墙钟时间、进程树 RSS、超时、失败、模型调用和 token。原 CodeQL-AI 的 evaluation-design.md 只定义指标，没有实测耗时或内存；其中 16GB 是配置示例。

随附性能说明提供当前可复现的规划模块工程测量及完整任务测量入口。规划合成数据不属于大规模源码扫描数据。大规模 OpenHarmony 审计的正式性能表仍需要真实目标与完整运行日志。

9. 工程验证与已知限制

工程检查包括 Python 语法与导入、主体 validate/plan/prepare/status、无 CodeQL 条件下的源码证据判定、独立复核与错误证据处理，以及离线 HTML 的交接、恢复与约束边界。检查不运行真实 PoC，不调用模型或真实扫描引擎。

本交付提供源码、技术说明书、使用说明、原型 DEMO 和性能测量资料。完整参赛效果取决于后续真实任务、工具联调与漏洞材料。模型语义判断、局部符号建模、权限环境和跨线程路径都有适用边界；不以架构描述替代实验结果。

10. 来源与重构范围

主体来源：https://github.com/megakn1ght/audit-workflow-prompts ， commit 7bd9cd9cbea555980b347bfd71bd5e4e75087b9b。保留分片、角色协议、候选隔离、独立验证与 checkpoint ；修复迁移入口并接入统一 CLI。

辅助来源：https://github.com/Binnnn-Lab/CodeQL-AI ， commit 51dbf412f440f723746087588665646c0edadddd。保留必要源码、provider 和 MCP 入口，改为主体按需使用的辅助能力。统一契约、可选调用策略、演示、说明书和测量入口属于本工程重构内容。来源信息见 NOTICE.md ；暂不新增开源许可证。

官方题目：https://cpipc.acge.org.cn/cw/hp/2c90800c8093eef401809d33b36f0652 。交付件 1、2、3、5 的逐项状态见 competition-checklist.md。

附录：本次传入的记录摘要

以下仅统计调用方传入数据，不代表已运行扫描。


```
{
  "findingCount": 0,
  "decisionCount": 0,
  "decisions": []
}
```